

Actividad 4

CNOIV

JORGE CASTELO

UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI

FUNDAMENTOS DE CIBERSEGURIDAD

FECHA DE ENTREGA: 31 DE AGOSTO DE 2026

1. Objetivo de la actividad

Intentar simular un ataque de ingeniería social, generando un sitio falso y utilizando el método POST para atrapar lo que el usuario haya escrito.

Para esto usamos setoolkit de Kali y una p[ágina web falsa.

2. Descripción del escenario

Una página falsa de un portal de inicio de sesión cualquiera hecho con IA, para facilitar el trabajo y hacerlo más rápido, se especificó que no quería nada que se pareciera aun sitio real.

3. Configuración del laboratorio Para garantizar el aislamiento de la prueba y evitar la exposición a internet, se configuró una red virtual privada (Adaptador Solo Anfitrión / Red Interna).

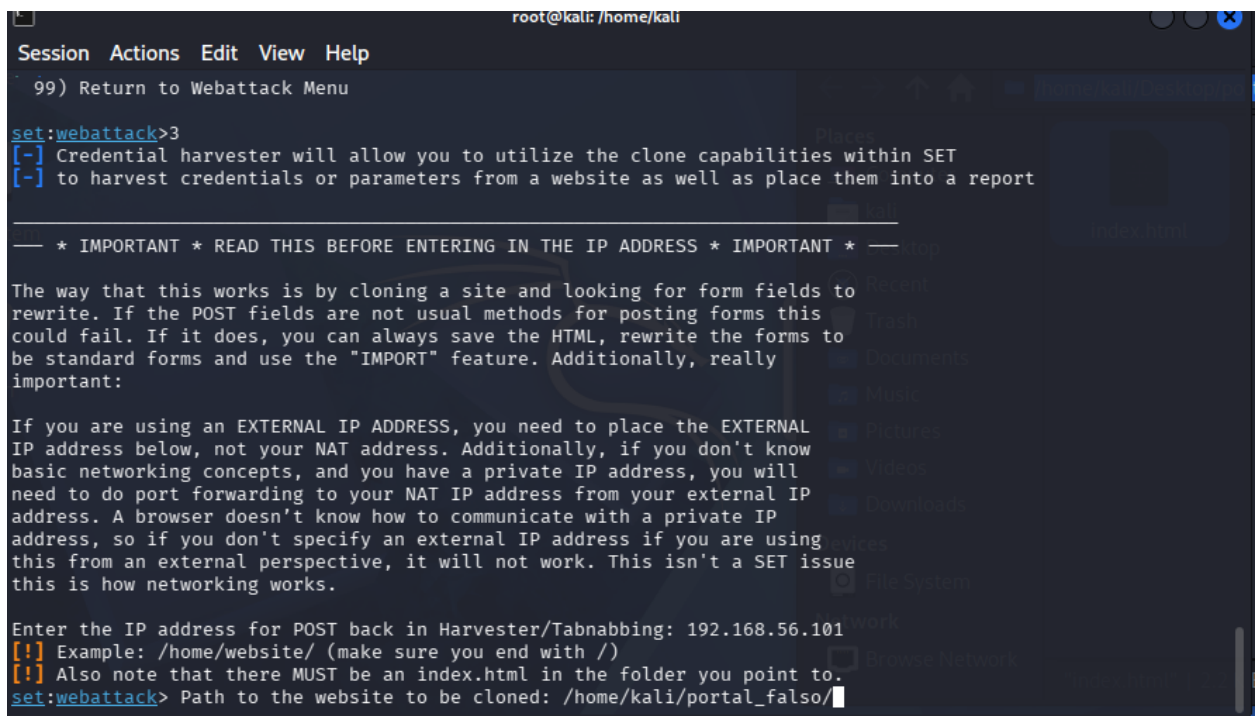
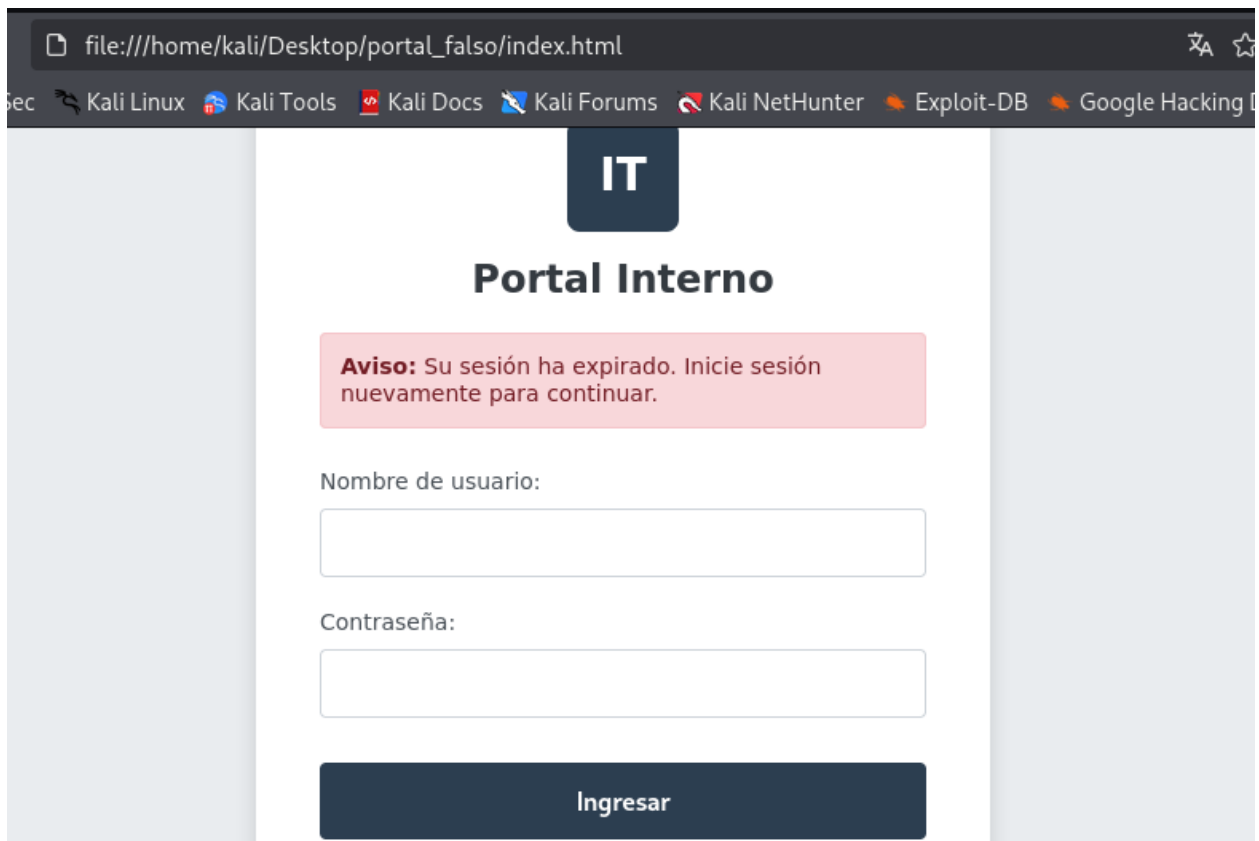
- **Máquina Atacante:** Kali Linux (IP: 192.168.56.101) ejecutando SEToolkit.
- **Máquina Víctima:** Windows 7 (IP: 192.168.56.102) como cliente simulado.
- **Página web:** Se desarrolló un archivo (La IA) HTML/CSS local con un formulario configurado con el método POST para capturar las variables de usuario y contraseña.

3. Evidencias y descripción del funcionamiento

- Captura del ping exitoso entre ambas máquinas.

```
(kali@kali)-[~]
$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data.
64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=9.83 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=4.35 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=128 time=2.03 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=128 time=4.27 ms
```

```
Ping statistics for 192.168.56.101:
  Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
  Minimum = 0ms, Maximum = 0ms, Average = 0ms
```



4. Explicación del flujo de captura de información y Diagrama

El ataque funciona explotando el protocolo HTTP sin cifrar:

1. La víctima realiza una petición **GET** a la IP del servidor falso.
2. El servidor (Kali/SET) responde entregando el portal HTML.
3. La víctima introduce sus datos y presiona enviar, generando una petición **POST**.
4. Al no existir cifrado SSL/TLS, SET opera localmente capturando los parámetros username y password directamente del cuerpo de la petición POST en texto plano, registrándolos antes de intentar cualquier redirección.

6. Indicadores visuales y técnicos de phishing

1. **URL anómala:** La dirección es una IP cruda (http://192.168.56.101) en lugar del dominio corporativo oficial.
2. **Ausencia de cifrado (SSL/TLS):** El navegador advierte que la conexión no es segura al no utilizar el protocolo HTTPS.
3. **Sentido de urgencia:** El mensaje "Su sesión ha expirado" presiona al usuario a actuar por instinto.
4. **Diseño genérico:** Carencia de certificados de identidad corporativa verificables en la página.
5. **Origen del vector:** El enlace original se distribuyó mediante correos no solicitados (spoofing).

6. Controles de seguridad

Autenticación Multifactor (MFA): Invalida el ataque; aunque el atacante obtenga la contraseña, no posee el token temporal del usuario.

1. **Gestores de contraseñas corporativos:** Estas herramientas se niegan a autocompletar credenciales si la URL actual no coincide exactamente con el dominio guardado.
2. **Soluciones EDR y Filtros de Correo:** Bloquean automáticamente correos con enlaces hacia direcciones IP directas o dominios no categorizados.
3. **Filtrado DNS (Sinkholing):** Impide a nivel de red que los equipos corporativos resuelven o naveguen hacia servidores maliciosos conocidos.

4. **Campañas de Concientización (Security Awareness):** Entrenamiento continuo a los empleados mediante phishing simulado para fomentar la verificación de URLs.